Conditional Access Security Posture Report

Northwind Trading | April 8, 2026

12	7	3	2
Policies	Enabled	Report-only	Disabled

Agenda

This report is structured for executive decisions first, evidence second, appendix last.

1. Posture Snapshot

Current score, trend signal, and policy status distribution.

- Scorecard
- State mix
- Assessment summary

2. Immediate Priorities

Top actions that reduce risk quickly in the next quarter.

- Top priorities
- 90-day roadmap

3. Supporting Analysis

Detailed evidence across MFA, risk, geography, and privileged access.

- Control evidence
- Policy overlap
- Recommendation detail

4. Appendix

Complete inventory and per-policy detail for audit and implementation.

- Policy matrix
- Policy-level breakdown

Posture Scorecard

Overall posture combines policy enforcement state and current recommendation backlog.

72
Stable posture

12
Total policies

7
Enabled

3
Report-only

2
Disabled

Assessment
GOOD - improvement actions required. 2 high | 2 medium | 1 low Critical gap: Phishing-resistant MFA is not consistently enforced for privileged roles.

Executive Summary

Headline + takeaway + evidence format is used across all sections.

Strengths

Legacy authentication is blocked for all users

- Legacy authentication is blocked for all users
- Risk-driven controls cover high user and sign-in risk
- Admin policies consistently require MFA

Concerns

Three report-only controls are older than six months

- Three report-only controls are older than six months
- Admin MFA is not phishing-resistant in all paths
- Two Microsoft-managed controls have no custom equivalent

Top Priorities

These actions represent the highest leverage improvements for the next review cycle.

Enforce phishing-resistant methods for privileged roles

Current admin policy allows standard MFA methods

Move token protection control from report-only to enabled

Control has been report-only since 2025-08-05

Close Microsoft-managed overlap gaps with custom controls

Two overlap rows are marked as Gap

90-Day Roadmap

Near-term items are immediate risk reducers. Mid-term items sustain posture improvements.

Near-term actions (0-45 days)

Execute first to reduce active exposure and remove stale report-only controls.

- Enable token protection for Exchange and SharePoint
- Move privileged role MFA to phishing-resistant strength

Mid-term actions (45-90 days)

Use these actions to harden role coverage and simplify policy operations.

- Close remaining Microsoft-managed overlap gaps
- Reduce standing active assignments in privileged roles

Supporting Analysis

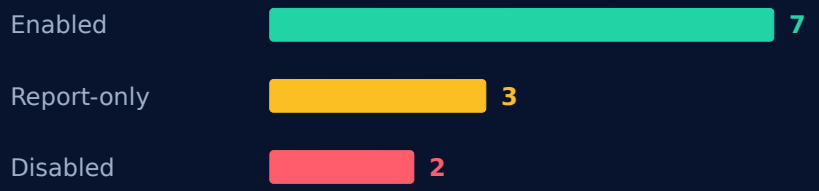
Control evidence and policy-level detail that supports the executive narrative.

Policy landscape | Geo strategy | MFA matrix | Risk controls | Auth strengths | PIM | Report-only | MS-managed overlap | Recommendations

Policy Landscape

7 12 policies are enforced. 3 remain in report-only mode.

Takeaway
Prioritize report-only conversions in parallel with high-severity gaps.



Geolocation Blocks
2 policies

MFA Enforcement
3 policies

Risk-Based Policies
2 policies

Access Blocking
1 policies

Device and Session
1 policies

Microsoft-managed
3 policies

Geolocation Strategy

3 geolocation layers are active in the tenant posture.

Takeaway

One country-specific policy is still report-only.

Layer 1 - Catch-all geo block

Main policy blocks non-approved countries and allows corporate regions only.

Layer 2 - Country-specific overlays

Country A (Enabled), Country B (Report-only)

Layer 3 - Trusted office location exclusions

Trusted office locations are excluded from some MFA challenges.

- 18 trusted locations

MFA Enforcement Matrix

3 MFA policy entries were analyzed for scope and control strength.

Takeaway
Confirm report-only MFA policies have transition plans to enforcement.

Policy	Scope	Auth strength	Frequency	Conditions
MFA - All users	All users	Built-in MFA	14 days	Trusted locations excluded
MFA - Privileged roles	Admin roles	Built-in MFA	7 days	All locations
MFA - Remote workforce	All users	Custom secure MFA	Every sign-in	VPN and high-value apps

Admin MFA posture
Privileged roles should move from standard MFA to phishing-resistant methods.

Identity Risk Policies

2 risk-focused policies were mapped to user and sign-in conditions.

Takeaway

High-risk users and high-risk sign-ins should have explicit enforcement and recovery paths.

High user risk

Risky Users - High

- Grant control: MFA + Password Change
- Operator: Require ALL
- Scope: All users
- Modified: 2024-11-19

High sign-in risk

Risky Sign-ins

- Grant control: Require MFA
- Operator: Require ONE
- Scope: All users
- Modified: 2025-01-10

Risk takeaway

Risk controls are present but privileged user coverage can be tightened.

Authentication Strengths

3 authentication strengths were evaluated for resistance and deployability.

Takeaway
Remove phishable factors from admin-facing strengths and map each strength to policy scope.

Passwordless Admin (Strongest)

Type: Custom | Methods: fido2, windowsHelloForBusiness

- Recommended baseline for privileged roles

Standard Workforce (Strong)

Type: Built-in | Methods: authenticatorPush, softwareOath

- General user coverage is adequate

Legacy Exception (Weak)

Type: Custom | Methods: sms

- Should be retired from admin-facing flows

Privileged Access Coverage

3 privileged roles were compared against Conditional Access targeting.

Takeaway

Roles without direct policy coverage should be prioritized in roadmap planning.

PIM role	Eligible	Active	CA coverage	Direct
Global Administrator	3	1	MFA - Privileged roles	Yes
Privileged Role Administrator	2	0	PIM auth context only	Partial
Security Administrator	4	1	No direct role-targeted policy	No

Coverage note

Partial means role coverage is indirect through shared controls.

Report-only Pipeline

3 report-only entries require staged conversion plans.

Takeaway

Use priority and staleness to define conversion waves.

Policy	Grant control	Target apps	Modified	Priority
Token protection rollout	Token protection	Exchange + SharePoint	2025-08-05	High
Admin portal geo constraint	Block access	Microsoft Admin Portals	2025-09-02	Medium
BYOD pilot	MFA + Compliant device	Office 365	2026-01-16	Low

Execution focus

High-priority report-only items should move into staged enforcement this quarter.

Microsoft-managed Overlap

3 auto-created policies were mapped against custom equivalents.

Takeaway

Any overlap marked as Gap should move into the high-priority backlog.

MS-managed policy	What it does	Custom equivalent	Overlap
MFA for admins at admin portals	Requires MFA for core admin roles in admin portals	MFA - Privileged roles	Full
Phishing-resistant MFA for admins	Requires phishing-resistant methods for admin roles	No custom equivalent	Gap
Block legacy authentication	Blocks legacy protocols for all users	Legacy authentication block	Full

Critical gap

No fully equivalent custom policy enforces phishing-resistant admin MFA.

Recommendation Inventory

5 recommendation items were grouped by severity for implementation planning.

Takeaway
Drive near-term delivery from the High group and keep Medium on a dated transition plan.

High priority
Enforce phishing-resistant MFA for privileged roles

High priority
Enable token protection controls for core workloads

Medium priority
Convert stale report-only controls with staged rollout windows

Medium priority
Add direct CA targeting for uncovered privileged roles

Low priority
Retire low-value legacy exceptions

Appendix

Policy inventory and detail are separated from the executive narrative.

Full Policy Matrix

12 policies are listed with state, action, scope summary, and modified date.

Takeaway
This appendix inventory is optimized for export and audit reference.

#	Policy	State	Action	Scope summary	Modified
1	Legacy authentication block	Enabled	Block	Users: All users, Apps: All cloud apps	2025-03-04
2	MFA - All users	Enabled	Grant	Users: All users, Apps: All cloud apps	2025-04-18
3	MFA - Privileged roles	Enabled	Grant	Apps: All cloud apps	2025-06-01
4	Risky Users - High	Enabled	Grant	Users: All users, Apps: All cloud apps	2024-11-19
5	Risky Sign-ins	Enabled	Grant	Users: All users, Apps: All cloud apps	2025-01-10
6	Geolocation catch-all block	Enabled	Block	Users: All users, Apps: All cloud apps	2025-02-14
7	Device registration control	Enabled	Grant	Users: All users	2025-05-20
8	Token protection rollout	Report-only	Grant	Users: All users, Apps: Office 365 Exchange Online, Mic...	2025-08-05
9	Admin portal geo control	Report-only	Block	Apps: Microsoft Admin Portals	2025-09-02
10	BYOD pilot	Report-only	Grant	Groups: Mobile Workforce, Apps: Office 365	2026-01-16
11	Microsoft-managed: Phishing-resistant MFA for admins	Disabled	Grant	Apps: All cloud apps	2024-12-12
12	Microsoft-managed: Require MFA for admins at admin portals	Disabled	Grant	Apps: Microsoft Admin Portals	2024-12-12

Policy Detail Appendix

12 policy detail slides (active controls only).

Legacy authentication block

ENABLED

Modified: 2025-03-04

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
Not configured	Not configured	exchangeActiveSync, other	Not configured	Not configured

USERS

- Include users: All users
- Exclude users: Break glass account

Block access

GRANT CONTROLS

Require ONE

[ ] Multifactor authentication
[ ] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: All cloud apps

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

MFA - All users

ENABLED

Modified: 2025-04-18

CONDITIONS

Platforms
Not configured

Locations
Exclude: Trusted office networks

Client Apps
browser, mobileAppsAndDesktopClients

Risk
Not configured

Devices
Not configured

USERS

- Include users: All users
- Exclude groups: Service Accounts

Grant access

GRANT CONTROLS

Require ONE

[x] Multifactor authentication
[ ] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: All cloud apps

SESSION CONTROLS

Sign-in frequency: 14 days

[ ] App enforced restrictions
[ ] Conditional Access App Control
[x] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

MFA - Privileged roles

ENABLED

Modified: 2025-06-01

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
Not configured	All locations	Not configured	Not configured	Not configured

USERS

- Include roles: Global Administrator, Security Administrator

Grant access

GRANT CONTROLS

Require ALL

[x] Multifactor authentication
[x] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: All cloud apps

SESSION CONTROLS

Sign-in frequency: 7 days

[ ] App enforced restrictions
[ ] Conditional Access App Control
[x] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

Risky Users - High

ENABLED

Modified: 2024-11-19

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
Not configured	Not configured	Not configured	Not configured	Not configured

USERS

- Include users: All users

Grant access

GRANT CONTROLS

Require ALL

[x] Multifactor authentication
[ ] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[x] Change password
[ ] Terms of use

APPS

- Include: All cloud apps

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

Risky Sign-ins

ENABLED

Modified: 2025-01-10

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
Not configured	Not configured	Not configured	Not configured	Not configured

USERS

- Include users: All users

Grant access

GRANT CONTROLS

Require ONE

[x] Multifactor authentication
[ ] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: All cloud apps

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

Geolocation catch-all block

ENABLED

Modified: 2025-02-14

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
Not configured	All | excl: CA, US, +1 more	Not configured	Not configured	Not configured

USERS

- Include users: All users

Block access

GRANT CONTROLS

Require ONE

[ ] Multifactor authentication
[ ] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: All cloud apps

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

Device registration control

ENABLED

Modified: 2025-05-20

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
All	Not configured	Not configured	Not configured	Not configured

USERS

- Include users: All users

Grant access

GRANT CONTROLS

Require ALL

[x] Multifactor authentication
[ ] Authentication strength
[x] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Actions: registerOrJoinDevices

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

Token protection rollout

REPORT-ONLY

Modified: 2025-08-05

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
windows, macOS	Not configured	Not configured	Not configured	Not configured

USERS

- Include users: All users

Grant access

GRANT CONTROLS

Require ALL

[x] Multifactor authentication
[ ] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use
[x] Token protection

APPS

- Include: Office 365 Exchange Online, Microsoft SharePoint Online

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[x] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

Admin portal geo control

REPORT-ONLY

Modified: 2025-09-02

CONDITIONS

Platforms
Not configured

Locations
Exclude: Trusted office networks

Client Apps
Not configured

Risk
Not configured

Devices
Not configured

USERS

- Include roles: Global Administrator, Privileged Role Administrator

Block access

GRANT CONTROLS

Require ONE

[ ] Multifactor authentication
[ ] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: Microsoft Admin Portals

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

BYOD pilot

REPORT-ONLY

Modified: 2026-01-16

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
android, iOS	Not configured	Not configured	Not configured	Not configured

USERS

- Include groups: Mobile Workforce

Grant access

GRANT CONTROLS

Require ALL

[x] Multifactor authentication
[ ] Authentication strength
[x] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: Office 365

SESSION CONTROLS

Sign-in frequency: 8 hours

[ ] App enforced restrictions
[ ] Conditional Access App Control
[x] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

Phishing-resistant MFA for admins

DISABLED

Modified: 2024-12-12

CONDITIONS

Platforms	Locations	Client Apps	Risk	Devices
Not configured	Not configured	Not configured	Not configured	Not configured

USERS

- Include roles: Global Administrator, Security Administrator

Grant access

GRANT CONTROLS

Require ALL

[x] Multifactor authentication
[x] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: All cloud apps

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection

Require MFA for admins at admin portals

DISABLED

Modified: 2024-12-12

CONDITIONS

Platforms
Not configured

Locations
Not configured

Client Apps
Not configured

Risk
Not configured

Devices
Not configured

USERS

- Include roles: Global Administrator, Privileged Role Administrator

Grant access

GRANT CONTROLS

Require ONE

[x] Multifactor authentication
[ ] Authentication strength
[ ] Compliant device
[ ] Hybrid Azure AD joined
[ ] Approved client app
[ ] App protection policy
[ ] Change password
[ ] Terms of use

APPS

- Include: Microsoft Admin Portals

SESSION CONTROLS

[ ] App enforced restrictions
[ ] Conditional Access App Control
[ ] Sign-in frequency
[ ] Persistent browser session
[ ] Continuous access evaluation
[ ] Disable resilience defaults
[ ] Token protection